XOR SECURE CLOUD

Quy chế và quy trình bảo đảm an ninh mạng XOR SECURE CLOUD

Dự thảo kèm quyết định ban hành của chủ quản

Nền tảng XOR STACK CLOUD dựa trên OpenStack

DC tại Trung tâm Hạ tầng IDC Cầu Giấy
DR tại Trung tâm Hạ tầng IDC Nam Thăng Long

Bản dự thảo 2.0 ngày 17 tháng 10 năm 2026

Ban hành kèm theo Quyết định số [CẦN ĐIỀN] ngày [CẦN ĐIỀN] của [CẦN ĐIỀN TÊN PHÁP NHÂN CHỦ QUẢN]. Quy chế chỉ có hiệu lực theo văn bản ban hành hợp lệ; nội dung dự thảo phải được rà soát phù hợp tổ chức, hợp đồng và cấu hình thực tế trước khi ký.

Điều 1 Phạm vi và đối tượng áp dụng

Quy chế áp dụng cho toàn bộ nền tảng XOR STACK CLOUD và dịch vụ quản trị chung tại IDC Cầu Giấy, IDC Nam Thăng Long; nhân sự XOR, đơn vị vận hành, đơn vị an ninh và bên thứ ba có quyền tác động đến hệ thống trong phạm vi hợp đồng.

Điều 2 Nguyên tắc bảo vệ

Bảo vệ theo cấp độ được phê duyệt; quản lý theo rủi ro; quyền tối thiểu; tách nhiệm vụ; phân vùng và chặn mặc định; bảo vệ dữ liệu theo phân loại; kiểm chứng bằng bằng chứng và phép thử. Việc mua sắm thiết bị hoặc ban hành quy trình không thay thế trách nhiệm triển khai và duy trì hiệu lực.

Điều 3 Trách nhiệm

Chủ quản phê duyệt phạm vi, nguồn lực, rủi ro và quyết định theo thẩm quyền. Đơn vị vận hành triển khai, cập nhật hiện trạng và khắc phục. Đơn vị chuyên trách về an ninh mạng hướng dẫn, kiểm tra và cho ý kiến chuyên môn. GRC quản lý hồ sơ; SOC giám sát 24/7; chủ tài sản chịu trách nhiệm dữ liệu và quyền. Người thực hiện và người xác nhận phải tuân thủ cơ chế độc lập chuyên môn đã được giao.

Điều 4 Tổ chức thực thi và lưu hồ sơ

Mỗi quy trình QT01–QT12 phải được gắn đầu mối chính, dự phòng và danh sách hệ thống áp dụng. Kết quả thực hiện được lưu bằng mã hồ sơ/ticket, ngày, phiên bản, người lập và xác nhận. Hồ sơ có dữ liệu nhạy cảm được cấp quyền tối thiểu; bản gửi bên ngoài chỉ chứa thông tin cần thiết và được chủ quản cho phép.

Điều 5 Xử lý trường hợp khẩn cấp và ngoại lệ

Trường hợp khẩn cấp thực hiện theo phân quyền và điều kiện dừng đã quy định, có ghi log và hậu kiểm. Ngoại lệ phải nêu yêu cầu, lý do, rủi ro, biện pháp bù, thời hạn và người phê duyệt; được rà soát khi hết hạn hoặc thay đổi. Không dùng ngoại lệ nội bộ để thay yêu cầu bắt buộc khi quy định không cho phép.

Điều 6 Kiểm tra và cập nhật

Đơn vị chuyên trách theo dõi lịch kiểm tra, tình trạng bằng chứng và hành động khắc phục; báo cáo chủ quản các mục chưa đáp ứng. Quy chế và quy trình được rà soát theo tần suất tương ứng trong TCVN, khi thay đổi tổ chức/kiến trúc hoặc sau sự cố. Các mốc phản ứng, thời hạn vá và mục tiêu phục hồi phải được chốt trong phụ lục vận hành có người duyệt.

Tham số phải phê duyệt	Giá trị hoặc văn bản
Chỉ huy sự cố/DR và người dự phòng	[CẦN ĐIỀN họ tên, vai trò, liên hệ và quyền quyết định]
Thời gian phản ứng và báo cáo sự cố	[CẦN ĐIỀN theo loại sự cố và nghĩa vụ pháp lý/hợp đồng]
Thời hạn xử lý lỗ hổng theo rủi ro	[CẦN ĐIỀN mức, thời hạn, ngoại lệ và quyền phê duyệt]
RPO RTO lịch backup và bất biến	[CẦN ĐIỀN theo BIA từng dịch vụ]
Lưu giữ hồ sơ và bằng chứng	[CẦN ĐIỀN theo loại; log ANM/camera bảo đảm tối thiểu 6 tháng theo TCVN]

QT01 Quản lý rủi ro và ngoại lệ

Trách nhiệm: GRC; chủ quản phê duyệt.

Căn cứ: TCVN 6.1; 6.4; 6.15. Tần suất: Ít nhất 6 tháng nhận diện/đánh giá hiệu lực; quy trình hằng năm và khi thay đổi.

Bước 1. Chủ tài sản cung cấp danh mục, dữ liệu, phụ thuộc và hậu quả gián đoạn; GRC nhận diện mối đe dọa, điểm yếu, nhà cung cấp và sự kiện có thể xảy ra.

Bước 2. Nhóm đánh giá xác định khả năng, tác động và căn cứ; BIA xem xét cả khách hàng, lợi ích công cộng, trật tự/an toàn xã hội hoặc an ninh quốc gia nếu liên quan.

Bước 3. Chọn tránh, giảm, chuyển giao hoặc chấp nhận theo thẩm quyền; chỉ định người, hạn, kinh phí và chỉ tiêu kiểm tra; quản lý biện pháp tương đương bằng hồ sơ riêng.

Bước 4. Đầu mối kỹ thuật triển khai qua quản lý thay đổi; người kiểm tra xác nhận hiệu lực; GRC đánh giá tồn dư và trình chủ quản.

Bước 5. Theo dõi thay đổi, thông báo bên liên quan và đóng có chứng cứ. Ngoại lệ có lý do, thời hạn, biện pháp bù và người duyệt; không thay thế yêu cầu bắt buộc.

Hồ sơ lưu và điều kiện hoàn thành

Sổ rủi ro, BIA, phiếu ngoại lệ, kế hoạch xử lý, biên bản xác nhận và quyết định chấp nhận.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT02 Quản lý tài sản dữ liệu và vòng đời

Trách nhiệm: Hạ tầng, Platform, chủ dữ liệu.

Căn cứ: TCVN 6.2–6.4. Tần suất: Kiểm kê hằng năm; phát hiện phần cứng/DHCP hằng quý; phần mềm trái phép 6 tháng; rà quyền dữ liệu hằng quý.

Bước 1. Tiếp nhận tài sản có chủ sở hữu, ID, site/rack/vùng, IP/MAC/serial, phiên bản, EOL, mục đích và bằng chứng kiểm tra trước sử dụng.

Bước 2. Cập nhật CMDB, danh mục phần mềm và dữ liệu; phân loại độ nhạy cảm, quyền, thời hạn lưu và hủy; phần mềm phải thuộc danh sách được phép.

Bước 3. Đối soát discovery, DHCP/IPAM, inventory OpenStack và danh mục; xử lý tài sản lạ bằng từ chối/cách ly/tiếp nhận có phê duyệt.

Bước 4. Khi thay đổi hoặc thu hồi, cập nhật quan hệ tài sản/dữ liệu và quyền; kiểm tra snapshot, backup, image và dữ liệu còn lại theo thời hạn áp dụng.

Bước 5. Thanh lý bằng phương pháp sanitize phù hợp media hoặc hủy vật lý; lập biên bản, xác minh và đóng vòng đời trong CMDB.

Hồ sơ lưu và điều kiện hoàn thành

CMDB, catalog phần mềm/SBOM, danh mục dữ liệu, ACL, phiếu tiếp nhận và biên bản hủy.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT03 Quản lý tài khoản và truy cập đặc quyền

Trách nhiệm: IAM; chủ tài sản duyệt; bảo mật kiểm tra.

Căn cứ: TCVN 6.6; 6.12.2.5–6.12.2.6. Tần suất: Rà tài khoản ít nhất hằng quý; rà quy trình hằng năm; thu hồi ngay theo thay đổi nhân sự.

Bước 1. Người yêu cầu lập phiếu nêu hệ thống, vai trò, mục đích, thời hạn và người quản lý; chủ tài sản xét quyền tối thiểu, tách nhiệm vụ.

Bước 2. IAM tạo tài khoản cá nhân/nhóm kỹ thuật có người sở hữu; áp MFA đối với đặc quyền, bên ngoài và đối tác; tách tài khoản vận hành với tài khoản tenant.

Bước 3. Truy cập từ PAW được bảo vệ qua gateway và PAM; chỉ đích/lệnh/quyền/thời gian được duyệt; ghi phiên và log; không cấp route rộng hoặc Internet cho tài nguyên quản trị.

Bước 4. Thay đổi/thu hồi qua ticket, đối soát tất cả hệ thống liên quan; vô hiệu tài khoản nhàn rỗi sau 45 ngày theo điều khoản; quản lý ngoại lệ và tài khoản mặc định.

Bước 5. Khẩn cấp dùng danh tính được kiểm soát, cảnh báo, giới hạn thời gian và hậu kiểm; người có quyền không tự phê duyệt và xóa dấu vết phiên của mình.

Hồ sơ lưu và điều kiện hoàn thành

Phiếu cấp/đổi/thu hồi, ma trận quyền, log MFA/PAM, rà soát quý và biên bản khẩn cấp.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT04 Cấu hình thay đổi và bản vá

Trách nhiệm: Platform và Network; CAB hoặc người được giao duyệt.

Căn cứ: TCVN 6.5; 6.7; 6.12. Tần suất: Scan toàn hệ thống 6 tháng, tài sản quan trọng quý; máy người dùng kiểm tra vá tháng; baseline/quy trình theo điều khoản.

Bước 1. Duy trì baseline theo loại tài sản, bản dựng và yêu cầu an ninh; ghi nhận port/service, xác thực, thời gian, log, mã hóa, session và cấu hình không được phép.

Bước 2. Tiếp nhận CVE/thay đổi; đánh giá phạm vi, mức rủi ro và phụ thuộc; xác định kiểm thử, phương án rollback, cửa sổ và người phối hợp.

Bước 3. Thử trên môi trường phù hợp, kiểm tra tương thích/hiệu năng; chỉ triển khai sau phê duyệt; nhập gói đã kiểm tra vào kho nội bộ thay vì mở Internet mạng quản trị.

Bước 4. Thực hiện theo kế hoạch, lưu cấu hình trước/sau và log; kiểm tra chức năng/an ninh, rollback khi vượt điều kiện dừng đã chốt.

Bước 5. Cập nhật CMDB/baseline/sơ đồ, scan và retest; ngoại lệ có hạn và kiểm soát bù; theo dõi drift và tài sản hết hỗ trợ.

Hồ sơ lưu và điều kiện hoàn thành

Yêu cầu thay đổi, đánh giá tác động, phê duyệt, log triển khai, rollback, scan và retest.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT05 Bảo vệ dữ liệu khóa và chữ ký số

Trách nhiệm: Chủ dữ liệu; quản trị khóa; bảo mật.

Căn cứ: TCVN 6.4; 6.11. Tần suất: Theo vòng đời dữ liệu/khóa; rà quyền và log dữ liệu ít nhất hằng quý.

Bước 1. Lập danh mục dữ liệu, chủ sở hữu, phân loại, luồng, quyền truy cập và nghĩa vụ lưu/hủy; xác định dữ liệu quan trọng và giao dịch cần chữ ký số.

Bước 2. Áp mã hóa lưu và truyền hoặc phương án tương đương có thuyết minh; luồng quan trọng kiểm tra hai lớp mã hóa đồng thời theo yêu cầu; dùng thuật toán mạnh.

Bước 3. Quản lý sinh, phân phối, dùng, luân chuyển, thu hồi, sao lưu và khôi phục khóa; người quản trị khóa và hạ tầng tách nhiệm vụ; không lưu bí mật trong code/hồ sơ.

Bước 4. Giám sát toàn vẹn, DLP và truy cập dữ liệu; ghi việc xuất/sao chép; xác minh chữ ký, chứng thư và quyền khi trao đổi dữ liệu quan trọng.

Bước 5. Hủy dữ liệu/khóa theo phân loại và thời hạn; khi lộ khóa, kích hoạt ứng phó, thu hồi, thay thế và kiểm tra ảnh hưởng bản sao.

Hồ sơ lưu và điều kiện hoàn thành

Danh mục dữ liệu, DFD, ma trận mật mã, log KMS, chứng thư, thử restore khóa, log DLP và biên bản hủy.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT06 Nhật ký giám sát và trực an ninh

Trách nhiệm: SOC và SecOps.

Căn cứ: TCVN 6.8; 6.10; 6.13. Tần suất: Trực 24/7; log tối thiểu 6 tháng; rà log tháng; điều chỉnh cảnh báo quý.

Bước 1. Lập ma trận tài sản/nguồn log, loại sự kiện và trường dữ liệu; đồng bộ giờ; cấu hình agent/collector có xác thực và giám sát mất nguồn.

Bước 2. Thu log vào vùng Z08 khác vùng sinh log; giới hạn quyền, chống sửa/xóa; tính dung lượng theo số đo, cảnh báo đầy kho và xác minh retention.

Bước 3. SOC nhận cảnh báo, phân loại, xác minh, mở ticket và chuyển chỉ huy theo mức sự cố; ca sau nhận đầy đủ công việc đang mở.

Bước 4. Kết hợp EDR, network flow, WAF/IPS, IAM/PAM và dữ liệu ứng dụng; chỉ cô lập tài sản theo quyền hạn/playbook và lưu chứng cứ.

Bước 5. Rà soát nguồn, quy tắc và ngưỡng; thử use case; lập báo cáo hoạt động, sự kiện thiếu nguồn và hành động khắc phục.

Hồ sơ lưu và điều kiện hoàn thành

Lịch trực, log bàn giao, ma trận nguồn, rule, ticket, báo cáo tháng/quý và phép thử.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT07 Sao lưu và khôi phục dữ liệu

Trách nhiệm: Backup; chủ dịch vụ duyệt; người kiểm tra xác nhận.

Căn cứ: TCVN 6.11. Tần suất: Tần suất theo dữ liệu/BIA; thử khôi phục ít nhất 6 tháng; quy trình hằng năm/khi đổi.

Bước 1. Chốt danh mục dữ liệu/config/image/DB và khóa phụ thuộc; xác định lịch, RPO/RTO, retention, phương pháp nhất quán và kho độc lập.

Bước 2. Tự động chạy job, mã hóa dữ liệu nhạy cảm, quản lý phiên bản, quyền và giám sát lỗi; bảo vệ theo 3-2-1 hoặc phương án tương đương đã thuyết minh.

Bước 3. Theo dõi lần thành công, khối lượng, checksum, trạng thái bản sao ngoài miền lỗi chung; điều tra lỗi và chạy bù có kiểm soát.

Bước 4. Phục hồi vào vùng cô lập với bản sao được chọn; kiểm tra khóa, toàn vẹn và nghiệp vụ; đo dữ liệu mất/thời gian phục hồi so với mục tiêu.

Bước 5. Lập biên bản, khắc phục và retest; điều chỉnh lịch/khả năng lưu trữ khi dữ liệu hoặc mục tiêu thay đổi.

Hồ sơ lưu và điều kiện hoàn thành

Catalog job, log, chứng cứ độc lập/bất biến nếu dùng, checksum và biên bản restore.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT08 Chuyển đổi DR và khởi động lại nền tảng

Trách nhiệm: Chỉ huy DR; Platform; chủ quản quyết định.

Căn cứ: TCVN 6.11; 6.12; BIA và thiết kế XOR. Tần suất: Theo kế hoạch được phê duyệt và khi thay đổi lớn; mục tiêu do BIA quyết định.

Bước 1. Xác nhận sự cố, phạm vi, trạng thái dữ liệu/replica và điều kiện kích hoạt; chỉ huy xin quyết định theo phân quyền và thông báo đầu mối liên quan.

Bước 2. Cô lập nguồn ghi ở DC bằng cơ chế fencing được thiết kế; xác định bản dữ liệu hợp lệ; ghi thời điểm giao dịch cuối cùng có thể khôi phục.

Bước 3. Phục hồi mạng, thời gian, DNS, IAM/khóa, lưu trữ, DB/queue, API và workload theo đồ thị phụ thuộc; dùng bí mật khẩn cấp có kiểm soát khi cần.

Bước 4. Kiểm tra nghiệp vụ và năng lực DR, ghi RPO/RTO từng dịch vụ; mở lưu lượng theo phê duyệt, theo dõi lỗi và tính nhất quán.

Bước 5. Chuyển về sau sửa lỗi, đồng bộ và đối soát; có điểm quyết định/rollback; diễn tập cả failback và khởi động nguội, lưu toàn bộ timeline.

Hồ sơ lưu và điều kiện hoàn thành

BIA, runbook, sơ đồ phụ thuộc, quyết định kích hoạt, fencing log, số đo và biên bản chuyển về.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT09 Ứng phó sự cố và bảo toàn chứng cứ

Trách nhiệm: CSIRT; SOC; pháp chế; chủ quản.

Căn cứ: TCVN 6.17. Tần suất: Diễn tập ít nhất hằng năm; rà quy trình/ngưỡng/danh bạ hằng năm hoặc khi đổi.

Bước 1. SOC tiếp nhận, mở mã sự cố, phân loại và báo đầu mối chính/dự phòng; ghi người, thời gian, tài sản, ảnh hưởng và dấu hiệu ban đầu.

Bước 2. Chỉ huy phân công kiểm soát sự cố; cô lập theo playbook, tránh phá chứng cứ; lưu bản gốc, hash, chuỗi bàn giao và quyền truy cập.

Bước 3. Điều tra phạm vi, nguyên nhân, dữ liệu ảnh hưởng; phối hợp IDC/ISP/đối tác và cơ quan có thẩm quyền theo nghĩa vụ áp dụng; pháp chế xác nhận thông báo bên ngoài.

Bước 4. Loại bỏ nguyên nhân, vá/cấu hình lại, khôi phục bản sạch, đổi khóa khi cần và kiểm tra trước mở dịch vụ.

Bước 5. Hậu kiểm timeline, tác động, quyết định và bài học; giao hành động, hạn, retest; rà lại ngưỡng và tổ chức diễn tập.

Hồ sơ lưu và điều kiện hoàn thành

Hồ sơ sự cố, log gốc, chuỗi chứng cứ, thông báo, quyết định, biên bản khôi phục và hậu kiểm.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT10 Phát triển đóng gói và phát hành XOR STACK

Trách nhiệm: DevSecOps; reviewer; người duyệt production.

Căn cứ: TCVN 6.16. Tần suất: Mỗi phát hành/thay đổi; danh mục bên thứ ba quý; đào tạo và quy trình hằng năm.

Bước 1. Yêu cầu và threat model xác định tài sản, ranh giới tenant, dữ liệu, API, session và yêu cầu an ninh cần kiểm thử.

Bước 2. Phát triển trong môi trường riêng; review code; không lưu bí mật; quản lý dependency, SBOM, bản quyền và nguồn upstream.

Bước 3. Chạy SAST/SCA/secret scan và kiểm thử chức năng/an ninh; xử lý lỗ hổng và pentest trước production theo phạm vi; ghi nhận ngoại lệ đúng thẩm quyền.

Bước 4. Đóng gói bản dựng có commit, digest và chữ ký theo thiết kế; lưu provenance; runner có quyền hẹp; phê duyệt release và kế hoạch rollback.

Bước 5. Triển khai, xác minh bản đang chạy, theo dõi lỗi và rollback khi cần; tiếp nhận báo cáo bên ngoài, RCA và bổ sung kiểm thử chống tái diễn.

Hồ sơ lưu và điều kiện hoàn thành

Yêu cầu, threat model, review, SBOM, scan/pentest, release manifest, log deploy và rollback.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT11 Quản lý nhân sự nhà cung cấp và vật lý

Trách nhiệm: HR; mua sắm; IDC; chủ quản.

Căn cứ: TCVN 6.14; 6.15; A.4. Tần suất: Đào tạo và rà danh mục/quy định hằng năm; theo sự kiện nhân sự/hợp đồng; camera ít nhất 6 tháng.

Bước 1. Chủ quản giao riêng vai trò vận hành, quản trị và an ninh; HR xác minh năng lực, NDA, đào tạo và quyền được cấp.

Bước 2. Mua sắm phân loại nhà cung cấp, kiểm tra điều kiện tương ứng dịch vụ, phạm vi trách nhiệm và yêu cầu bảo mật trong hợp đồng.

Bước 3. IDC và XOR quản lý người ra vào, khách, rack, điện/UPS, PCCC, nước, môi trường và điện từ; lưu camera và log theo yêu cầu; cung cấp bằng chứng từng site.

Bước 4. Theo dõi SLA, truy cập nhà cung cấp và bảo trì; giám sát mọi phiên đặc quyền; xử lý sự cố theo đầu mối đã chốt.

Bước 5. Khi nhân sự hoặc hợp đồng kết thúc, thu hồi thẻ/tài khoản/tài sản, bàn giao dữ liệu và log, xác nhận xóa theo nghĩa vụ; kiểm tra không còn truy cập.

Hồ sơ lưu và điều kiện hoàn thành

Quyết định phân công, hồ sơ đào tạo/NDA, hợp đồng/SLA, bằng chứng IDC, phiếu thu hồi.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].

QT12 Kiểm tra nghiệm thu và quản lý hồ sơ

Trách nhiệm: GRC; đơn vị kiểm tra; chủ quản.

Căn cứ: TCVN 6.12.2.7; 6.18. Tần suất: Pentest ngoài và trong mỗi loại ít nhất hằng năm; kiểm tra trước vận hành/phát hành theo phạm vi.

Bước 1. Lập phạm vi, mục tiêu, tiêu chí, ROE, thời gian, dữ liệu thử, điều kiện dừng và đầu mối; người có thẩm quyền phê duyệt trước thử.

Bước 2. Tổ chức kiểm tra có tư vấn/giám sát độc lập theo yêu cầu; lưu bước, cấu hình, bản dựng, log và giới hạn phương pháp.

Bước 3. Lập phát hiện theo tài sản, tác động, bằng chứng; gắn người, hạn và hành động; không kết luận đạt ở nơi chưa đủ bằng chứng.

Bước 4. Retest sau khắc phục, đánh giá hiệu lực kiểm soát và lập biên bản nghiệm thu có xác nhận chuyên trách, trình chủ quản phê duyệt.

Bước 5. Đóng phiên bản hồ sơ, danh mục tài liệu/hash và quyền nhận; theo dõi phản hồi thẩm định; cập nhật khi phạm vi, dữ liệu hoặc kiến trúc thay đổi.

Hồ sơ lưu và điều kiện hoàn thành

ROE, báo cáo kiểm tra, findings, retest, nghiệm thu, danh mục hồ sơ và lịch sử thay đổi.

Hoàn thành khi các bước trong phạm vi đã thực hiện, bằng chứng có người kiểm tra và tồn tại đã được xử lý theo thẩm quyền. Đầu mối chính: [CẦN ĐIỀN]; dự phòng: [CẦN ĐIỀN]; ngày bắt đầu áp dụng: [CẦN ĐIỀN].